

2. VMA - Authentication - API Specifications for Mini App Backend

1. Standards

Tất cả các API xác thực tuân thủ **RFC 6749 (OAuth 2.0)** và **RFC 6750 (Bearer Token Usage)**.

2. Authentication (OAuth2)

Hệ thống sử dụng **chuẩn OAuth 2.0 – Client Credentials Grant** cho luồng xác thực giữa **đối tác (machine-to-machine)** và VETC.

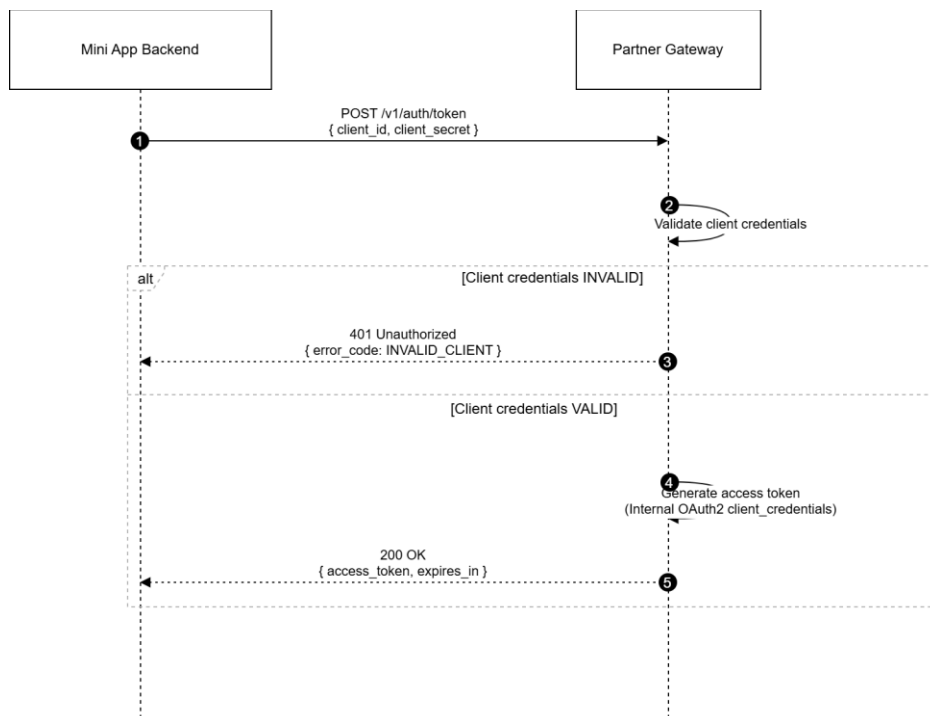
Đối tác được cấp một cặp **client_id / client_secret** và thực hiện gọi endpoint **/token** để lấy **access token**.

Access token này được sử dụng trong header **Authorization: Bearer** khi gọi các API protected của hệ thống.

Luồng này **không liên quan đến người dùng cuối, không có redirect, không có consent UI và không sử dụng refresh token**.

Access token có thời gian sống ngắn và có thể bị **revoke** khi cần thiết để đảm bảo an toàn.

Luồng xác thực tuân thủ đầy đủ tiêu chuẩn OAuth 2.0 và phù hợp cho các tích hợp server-to-server.



Endpoint

ENVIRONMENT	HTTP METHOD	API URL
UAT	POST	https://uat-apigw-kds.vetc.com.vn/partner-gateway/v1/auth/token
PROD	POST	https://apigw-kds.vetc.com.vn/partner-gateway/v1/auth/token

Headers

HEADER	REQUIRED	VALUE
Content-Type	✓	application/x-www-form-urlencoded

Request Body (form-urlencoded)

FIELD	REQUIRED	DESCRIPTION
grant_type	✓	client_credentials
client_id	✓	Client ID
client_secret	✓	Client Secret
scope		openid profile

Success Response

HTTP	CODE	MESSAGE
200	00	Thành công

```
{
  "access_token": "eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9...",
  "token_type": "Bearer",
  "expires_in": 3600,
  "scope": "openid profile"
}
```

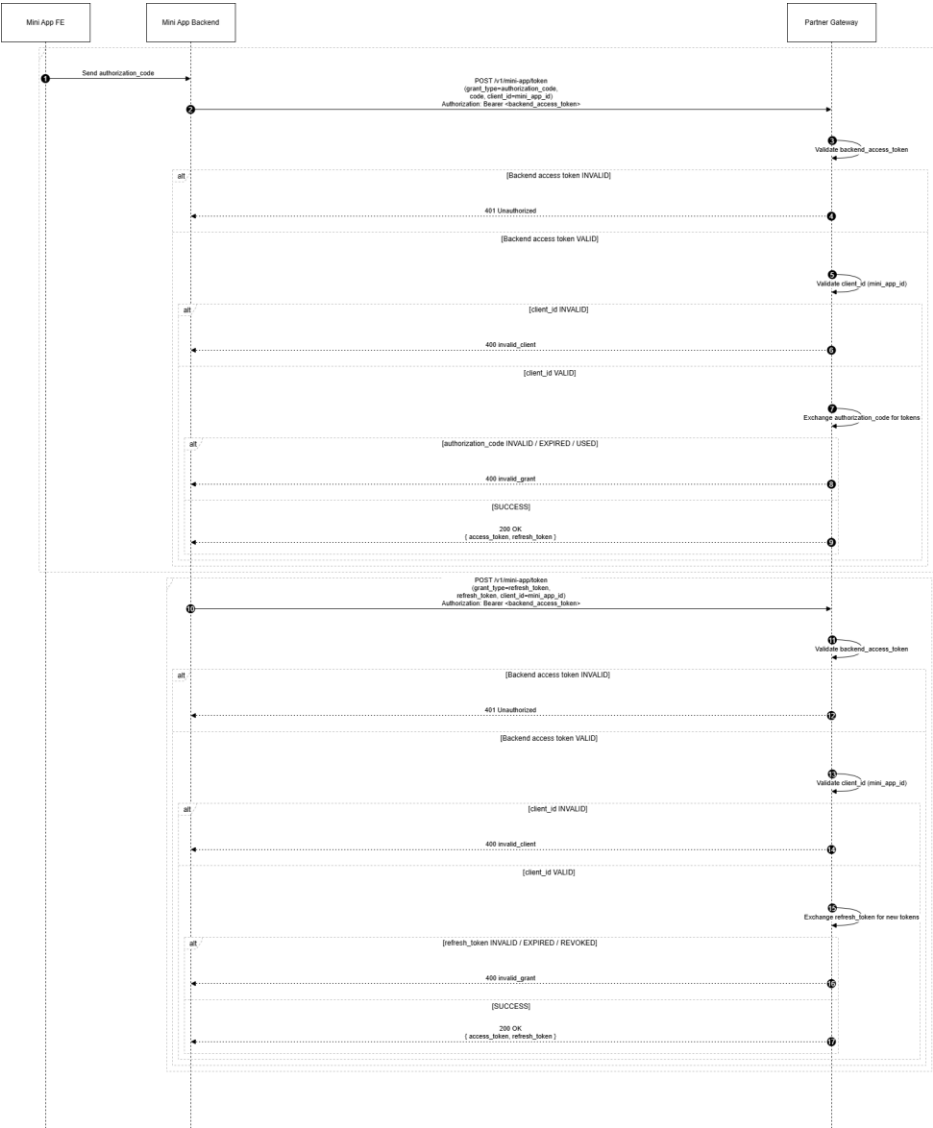
Error Response

HTTP	DESCRIPTION
400	Yêu cầu không hợp lệ

HTTP	DESCRIPTION
401	Client ID/Client Secret không đúng

```
{
  "error": "invalid_client",
  "error_description": "Invalid client or Invalid client credentials"
}
```

2. Create/Refresh User Access Token (OAuth2)



Luồng hoạt động

- Mini App FE nhận được **authorization code** và gửi về **Mini App Backend**.
- Backend gọi **Gateway** qua endpoint `POST /v1/mini-app/token`, kèm **backend access token** để xác thực.

- Gateway xác thực backend, kiểm tra **mini_app_id**, sau đó **đổi authorization code lấy access token và refresh token**.
- Nếu thành công, Gateway trả token cho backend; nếu thất bại, trả về các lỗi OAuth2 tương ứng.

Endpoint

ENVIRONMENT	HTTP METHOD	API URL
UAT	POST	https://uat-apigw-kds.vetc.com.vn/partner-gateway/v1/mini-app/token
PROD	POST	https://apigw-kds.vetc.com.vn/partner-gateway/v1/mini-app/token

Headers

HEADER	REQUIRED	VALUE
Content-Type	✓	application/x-www-form-urlencoded

Request Body (form-urlencoded)

Cho luồng tạo token

FIELD	REQUIRED	DESCRIPTION
grant_type	✓	authorization_code
client_id	✓	Client ID
client_secret	✓	Client Secret
code	✓	Auth code
redirect_uri		

Cho luồng refresh token

FIELD	REQUIRED	DESCRIPTION
grant_type	✓	refresh_token

FIELD	REQUIRED	DESCRIPTION
client_id	✓	Client ID
client_secret	✓	Client Secret
refresh_token	✓	Refresh Token

Success Response

HTTP	CODE	MESSAGE
200	00	Thành công

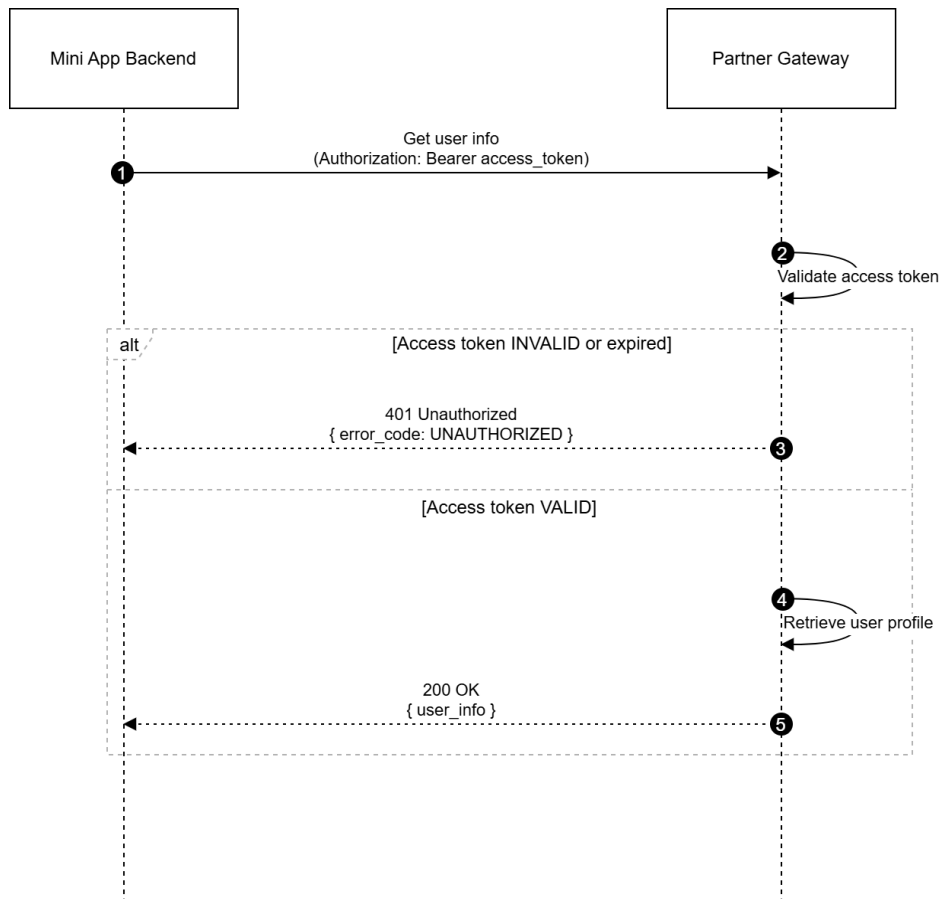
```
{
  "access_token": "eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9...",
  "expires_in": 8,
  "refresh_expires_in": 7775985,
  "refresh_token": "eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9...",
  "token_type": "Bearer",
  "id_token": "eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9...",
  "not-before-policy": 0,
  "session_state": "8ea226fb-670e-411e-a9b1-6f5f1566bd17",
  "scope": "openid profile email"
}
```

Error Response

HTTP	CODE	MESSAGE
400	BAD_REQUEST	Yêu cầu không hợp lệ (không đúng format)
401	UNAUTHORIZED	Access token không hợp lệ
422	INVALID_MINI_APP_ID	Mini App ID không đúng
422	INVALID_AUTH_CODE	Auth Code không đúng

```
{
  "error": "invalid_client",
  "error_description": "Invalid client or Invalid client credentials"
}
```

3. Get User Info



Endpoint

ENVIRONMENT	HTTP METHOD	API URL
UAT	GET	https://uat-apigw-kds.vetc.com.vn/partner-gateway/v1/mini-app/user
PROD	GET	https://apigw-kds.vetc.com.vn/partner-gateway/v1/mini-app/user

Headers

HEADER	REQUIRED	DESCRIPTION
Authorization	✓	Bearer <access_token>, access_token là token đã exchange từ auth code phía trên
Content-Type	✓	application/json

Accept	✓	application/json
--------	---	------------------

Success Response

HTTP	CODE	MESSAGE
200	00	Thành công

```
{
  "code": "00",
  "message": "Thành công",
  "data": {
    "name": "Full Name",
    "email": "you@example.com",
    "phone_number": "0987654321"
  }
}
```

Error Response

HTTP	CODE	MESSAGE
401	UNAUTHORIZED	Access token không hợp lệ

```
{
  "code": "UNAUTHORIZED",
  "message": "Access token không hợp lệ"
}
```